

CVEs más relevantes de la semana

Del 09/06/2026 al 16/06/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-47928

Descripción: ColdFusion versions 2023.19, 2025.8 and earlier are affected by an Improper Input Validation vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-06-09



CVE-2026-47929

Descripción: ColdFusion versions 2023.19, 2025.8 and earlier are affected by an Incorrect Authorization vulnerability that could result in arbitrary code execution in the context of the current user. A high-privileged attacker could exploit this vulnerability to gain elevated access or control over the victim's account or session. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 8.4 (HIGH)

Vector: CVSS:3.1/AV:A/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-06-09



CVE-2026-47931

Descripción: ColdFusion versions 2023.19, 2025.8 and earlier are affected by an Improper Input Validation vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 8.4 (HIGH)

Vector: CVSS:3.1/AV:A/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-06-09



CVE-2026-47932

Descripción: ColdFusion versions 2023.19, 2025.8 and earlier are affected by an Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability that could result in a Security feature bypass. An attacker could leverage this vulnerability to access unauthorized files or directories outside the intended restrictions. Exploitation of this issue requires user interaction in that a v...

CVSS: 8.8 (HIGH)

Vector: CVSS:3.1/AV:A/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-06-09



CVE-2026-48303

Descripción: Adobe Campaign Classic (ACC) versions 7.4.3 build 9394 and earlier are affected by an Incorrect Authorization vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-06-09



CVE-2025-66276

Descripción: QuTS hero is not affected.

We have already fixed the vulnerability in the following version:
QTS 5.2.7.3256 build 20250913 and later

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: NVD-CWE-noinfo

Tecnología: No especificado

Publicado el: 2026-06-10



CVE-2026-26240

Descripción: A buffer overflow vulnerability has been reported to affect File Station 5. The remote attackers can then exploit the vulnerability to modify memory or crash processes.

We have already fixed the vulnerability in the following version:
File Station 5 5.5.6.5243 and later

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-121

Tecnología: No especificado

Publicado el: 2026-06-10



CVE-2026-26241

Descripción: A buffer overflow vulnerability has been reported to affect File Station 5. The remote attackers can then exploit the vulnerability to modify memory or crash processes.

We have already fixed the vulnerability in the following version:
File Station 5 5.5.6.5243 and later

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-121

Tecnología: No especificado

Publicado el: 2026-06-10



CVE-2025-6254

Descripción: The Doctreat Core plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 1.6.8. This is due to the `doctreat_process_registration()` function not properly restricting the roles that a user can register with. This makes it possible for unauthenticated attackers to register as an administrator user.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-06-10



CVE-2026-53469

Descripción: A flaw was found in migration-planner. An authenticated user can exploit this vulnerability by sending a DELETE request to the /api/v1/sources route, which lacks proper authorization and filtering. This allows for the destruction of all customer data, including sources, agents, and assessments, leading to a critical loss of availability and integrity across the entire SaaS platform.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-06-10



CVE-2026-53470

Descripción: A flaw was found in migration-planner. An authenticated attacker could exploit an improper access control vulnerability in the `/api/v1/sources/{id}/image-url` endpoint. This flaw allows the attacker to bypass an ownership check and obtain presigned S3 URLs for Open Virtual Appliance (OVA) images belonging to other users. Consequently, the attacker can download OVA images containing sensitive i...

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-06-10



CVE-2026-53476

Descripción: A flaw was found in assisted-migration-agent. An unauthenticated attacker, located on the same local area network (LAN), can exploit a path traversal vulnerability. By crafting a specially designed gzipped tarball, the attacker can bypass security checks and write arbitrary files to the system. This could ultimately lead to the execution of unauthorized code on the appliance.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-59

Tecnología: No especificado

Publicado el: 2026-06-10



CVE-2026-41699

Descripción: Spring for GraphQL applications are vulnerable to Unsafe Deserialization when processing paginated GraphQL queries. An attacker can craft a malicious GraphQL request that can lead to Remote Code Execution when the application exposes a paginated (Connection) field and the classpath contains specific classes that can be leveraged during deserialization.

Affected versions: Spring for GraphQL 2.0...

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-06-11



CVE-2026-11561

Descripción: Improper neutralization of special elements used in an expression language statement ('expression language injection') vulnerability in Soagen Informatics Technologies Software and Consulting Inc. Apinizer allows Code Injection.

This issue affects Apinizer: from 2026.04.0 before 2026.04.6.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-917

Tecnología: No especificado

Publicado el: 2026-06-11



CVE-2026-7852

Descripción: Unrestricted upload of file with dangerous type vulnerability in Limatek System Inc. LimRAD NAC allows Remote Code Inclusion.

This issue affects LimRAD NAC: before 5.5.7.3.9.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-06-11



CVE-2026-11839

Descripción: Unrestricted upload of file with dangerous type vulnerability in Ba[arsoft Information Technologies Inc. Rotaban allows Upload a Web Shell to a Web Server.

This issue affects Rotaban: from V2026.06.002 before V2026.06.003.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-06-11



CVE-2026-49875

Descripción: Apache CXF's EndpointReferenceUtils and W3CMultiSchemaFactory classes construct a SAXParserFactory without the necessary JAXP hardening configurations, enabling out-of-band (OOB) external entity resolution. Users are recommended to upgrade to versions 4.2.2 or 4.1.7, which fix this issue.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-611

Tecnología: No especificado

Publicado el: 2026-06-12



CVE-2026-50627

Descripción: The JwtAccessTokenValidator class in Apache CXF fails to validate the 'aud' (Audience) claims of incoming JWT access tokens. This allows a JWT issued for one Resource Server to be successfully replayed against a completely different Resource Server, leading to Token Confusion/Routing attacks. Users are recommended to upgrade to versions 4.2.2 or 4.1.7, which fixes this issue.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-289

Tecnología: No especificado

Publicado el: 2026-06-12



CVE-2026-50628

Descripción: A logic error in OAuthRequestFilter rejects legitimate requests originating from the bound IP address, while blindly allowing requests from any other IP address. Enabling this security feature inadvertently creates an inverse security check. Users are recommended to upgrade to versions 4.2.2 or 4.1.7, which fixes this issue.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-06-12



CVE-2026-11849

Descripción: The iRM-IEI Remote Management developed by IEI Integration Corp has a Hardcoded Credentials vulnerability, allowing unauthenticated remote attackers to exploit hard-coded credentials to gain administrative privileges on the database.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-06-12



CVE-2026-45674

Descripción: Netty is a network application framework for development of protocol servers and clients. Prior to versions 4.1.135.Final and 4.2.15.Final, Netty's DnsResolveContext fails to validate the origin (bailiwick) of CNAME records in DNS responses. Versions 4.1.135.Final and 4.2.15.Final patch the issue.

CVSS: 8.7 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-345

Tecnología: No especificado

Publicado el: 2026-06-12



CVE-2026-53787

Descripción: Amasty Order Attributes for Magento 2 before version 4.0.0 contains an unauthenticated arbitrary file upload vulnerability that allows unauthenticated attackers to write arbitrary files to the store's media directory by submitting files of any type or name to the upload endpoint without authentication, session validation, or cart context. Attackers can upload PHP files to achieve remote code ex...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-06-12



CVE-2026-6853

Descripción: Improper restriction of excessive authentication attempts vulnerability in Bañbelen Group Food Cafe Businesses Industry and Trade Ltd. Co. Pause+ Mobile App allows Authentication Bypass.

This issue affects Pause+ Mobile App: from v1.0.6 before v1.5.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-307

Tecnología: No especificado

Publicado el: 2026-06-12



CVE-2026-47691

Descripción: Netty is a network application framework for development of protocol servers and clients. Prior to versions 4.1.135.Final and 4.2.15.Final, Netty's 'DnsResolveContext' insufficiently validates the bailiwick of NS records, enabling DNS Cache Poisoning. An attacker controlling an authoritative name server for a subdomain can poison the cache for parent domains (like '.co.uk'). In 'io.netty.resolv...

CVSS: 8.7 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-345

Tecnología: No especificado

Publicado el: 2026-06-12



CVE-2026-44170

Descripción: MariaDB server is a community developed fork of MySQL server. From versions 10.6.1 to before 10.6.26, 10.11.1 to before 10.11.17, 11.4.1 to before 11.4.11, 11.8.1 to before 11.8.7, and 12.3.1, MariaDB on Windows with installed CONNECT engine and enabled REST support interpolated table HTTP attribute into the curl command line without proper sanitizing. This allows the user to execute shell comm...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-06-12



CVE-2026-44172

Descripción: MariaDB server is a community developed fork of MySQL server. In versions 3.3.18 and 3.4.8, an application that was taking non-validated user input, escaping it with `mysql_real_escape_string()` and sending it to the database using text protocol and big5 character set was vulnerable to SQL injections, even though `mysql_real_escape_string()` was supposed to prevent them. This issue has been patched...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-06-12



CVE-2026-48558

Descripción: SimpleHelp versions 5.5.15 and prior and 6.0 pre-release versions contain an authentication bypass vulnerability in the OIDC authentication flow. When OIDC authentication is configured, identity tokens submitted during login are accepted without verifying their cryptographic signature. In a vulnerable configuration, a remote, unauthenticated attacker can submit a forged token containing arbitra...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-347

Tecnología: No especificado

Publicado el: 2026-06-12



CVE-2026-53838

Descripción: OpenClaw before 2026.5.27 contains a state mutation vulnerability in node pairing reconnection that allows paired nodes to confuse approval scope decisions. Attackers can exploit reconnection logic to restore or present broader node authority than intended, potentially bypassing approval restrictions.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-367

Tecnología: No especificado

Publicado el: 2026-06-12



CVE-2018-25436

Descripción: WordPress Plugin Baggage Freight Shipping Australia 0.1.0 contains an unrestricted file upload vulnerability that allows unauthenticated attackers to upload arbitrary files by exploiting the upload-package.php endpoint. Attackers can submit POST requests with malicious file extensions to the upload handler, which moves files without validation to the plugin upload directory, enabling remote cod...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-06-15



CVE-2026-53776

Descripción: Perry before 0.5.1166 contains a JWT validation vulnerability that allows remote attackers to bypass token expiration by exploiting the unconditional setting of `validate_exp = false` in the `verify_decode` helper within the `stdlib` JWT verification path. Attackers in possession of a previously issued bearer token can present expired tokens to any `jwt.verify()` call and retain authenticated access in...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-613

Tecnología: No especificado

Publicado el: 2026-06-16



Resumen del Reporte

CVEs analizados: 30

Promedio CVSS: 9.42

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

